



Universidad Nacional Experimental de Guayana.

Vicerrectorado Académico.

Coordinación General de Pregrado.

Proyecto de Carrera: Ingeniería en Informática.

Unidad Curricular: Ingeniería de Software II.

Gestión de Riesgos y Deuda Técnica.

Team Pixel & Code

“Estrategia, desarrollo y valor real”

Profesor:

Ms. Félix Márquez

Integrantes:

C.I.: V-28.530.717. Bravo Yvanna

C.I.: V-28.726.605. Guilarte Keibel

C.I.: V-19.505.397. Rivas Miguel

C.I.: V-24.848.424. Varguillas Génesis.

Ciudad Guayana, 16 de Septiembre del 2026.

Introducción

La gestión de riesgos en la ingeniería de software ha experimentado una transformación fundamental: de ser un ejercicio burocrático de llenado de matrices al inicio del proyecto ha evolucionado hacia una disciplina dinámica, continua y transversal a todo el ciclo de vida del desarrollo. Históricamente, los riesgos se abordaban de manera reactiva o se relegaban a un "Plan de Riesgos" estático que rara vez se actualizaba, contribuyendo al fracaso de numerosas iniciativas tecnológicas. Sin embargo, la naturaleza inherentemente compleja, intangible y volátil del desarrollo de software moderno exige un enfoque proactivo, empírico y adaptativo.

En la era digital, la ingeniería de software ha transicionado desde la construcción de sistemas monolíticos y aislados hacia la orquestación de ecosistemas hiperconectados, altamente distribuidos e interdependientes. Esta aceleración introduce una paradoja estructural: a mayor abstracción operativa y delegación en proveedores externos, mayor es la superficie de ataque y la complejidad en la gestión del riesgo. La responsabilidad técnica ya no se limita a garantizar el correcto funcionamiento del código propio, sino que abarca la supervisión continua, la trazabilidad y la gobernanza de componentes externos sobre los cuales se tiene control limitado o nulo.

Esta unidad aborda tanto los conceptos fundamentales de gestión de riesgos (identificación, análisis, priorización y control) como las realidades contemporáneas de la industria. Se integran amenazas modernas que definen el panorama tecnológico actual: la deuda técnica acumulada, las vulnerabilidades de ciberseguridad en la cadena de suministro de software (Supply Chain Attacks), el vendor lock-in en arquitecturas en la nube, y los riesgos éticos, legales y de alucinación asociados al uso de Inteligencia Artificial Generativa.

El objetivo es que el futuro ingeniero comprenda que gestionar riesgos no consiste en eliminar la incertidumbre (algo imposible en sistemas complejos), sino en construir resiliencia organizacional, tomar decisiones informadas y fomentar una cultura de transparencia donde los riesgos se discutan abiertamente en cada iteración, protegiendo así el valor del producto y la sostenibilidad del equipo.

1. Identificación y Análisis de Riesgos

Una fintech desarrolla una aplicación móvil de préstamos que utiliza una API de Inteligencia Artificial de un tercero para evaluar el riesgo crediticio de los usuarios, y toda la infraestructura está alojada en un único proveedor de nube (Serverless).

Risk Storming

Es una sesión colaborativa y visual donde todo el equipo (desarrolladores, QA, Product Owner, Arquitectos, DevOps) identifica riesgos de manera democrática e integrada. A diferencia de sesiones tradicionales lideradas únicamente por el PM, este enfoque multifuncional detecta riesgos técnicos, de ciberseguridad y operacionales que de otro modo serían invisibles.

Aspecto	Detalles
Participantes	Desarrolladores, QA, Product Owner, Arquitecto, DevOps/SRE
Técnicas	Análisis de arquitectura, diagramas de flujo, matriz de riesgos, lluvia de ideas colaborativa, priorización participativa
Duración	2-3 horas en sesión condensada

Mediante la sesión de Risk Storming, se identificaron cuatro (4) riesgos específicos, uno de cada categoría requerida:

a) Riesgo Técnico / Deuda Técnica

Para cumplir con el plazo de lanzamiento, el equipo implementa la integración con la API de IA de terceros sin un manejo robusto de errores ni lógica de reintentos (retry logic). Esta decisión, tomada bajo presión de tiempo, genera deuda técnica que se manifestará como fallos en producción cuando la API externa presente latencia, timeouts o caídas temporales del servicio.

Naturaleza de la deuda: Siguiendo el Cuadrante de Fowler, se trataría de una deuda deliberada e imprudente si se conoce el riesgo y aun así se omite el control, o deliberada y prudente si se documenta como pendiente técnico a resolver en un sprint posterior.

Consecuencia de negocio: Interrupciones del servicio de aprobación de préstamos, pérdida de

confianza del usuario y costos de remediación crecientes cuanto más tiempo se posponga la corrección.

b) Riesgo de Ciberseguridad / Cadena de Suministro

La API de IA de terceros podría tener una vulnerabilidad no detectada (por ejemplo, dependencias o librerías desactualizadas del lado del proveedor), exponiendo datos sensibles de crédito de los usuarios a una brecha de seguridad que está fuera del control directo de la fintech.

c) Riesgo de Vendor Lock-in

Al usar servicios propietarios Serverless de un único proveedor de nube (funciones, base de datos gestionada, colas de eventos), migrar a otro proveedor en el futuro implicaría reescribir gran parte de la arquitectura, dejando a la empresa sin poder real de negociación de precios.

d) Riesgo Ético / Legal (IA)

El modelo de IA de terceros podría generar sesgos algorítmicos al evaluar el riesgo crediticio (por ejemplo, discriminar de forma indirecta por zona geográfica o género), exponiendo a la fintech a demandas regulatorias por incumplimiento de normativas de protección de datos y no discriminación.

Selección del riesgo de mayor puntuación

Se elige el riesgo (d) Ético/Legal (IA) — sesgo algorítmico — como el de mayor prioridad, ya que combina una alta probabilidad de ocurrencia (el modelo de IA de terceros funciona como una "caja negra" difícil de auditar) con un impacto severo (sanciones regulatorias, demandas legales y daño reputacional irreversible).

Análisis Cualitativo — Cálculo del Risk Score

Variable	Valor	Justificación
Probabilidad	4 (Alta)	El modelo de IA es una "caja negra" externa; la fintech no controla ni audita directamente los datos de entrenamiento del proveedor.
Impacto	5 (Muy Alto)	Multas regulatorias (GDPR/LGPD), demandas legales por discriminación, pérdida de licencia operativa y daño reputacional.

Risk Score = Probabilidad × Impacto

Risk Score = $4 \times 5 = 20 / 25$ (MÁXIMA CRITICIDAD)

Sobre una escala de 1 a 25, se ubica en la zona crítica, requiriendo acción inmediata antes del lanzamiento.

Estrategia De Respuesta Y Mitigación

Estrategia seleccionada: Mitigar (Mitigation)

Nombre de la estrategia: Implementación de un Framework de Gobernanza y Explicabilidad de IA (*Explainable AI - XAI*) + Auditoría de Cadena de Suministro (SBOM).

Descripción de la estrategia: Dado que no se puede *evitar* el riesgo sin cancelar el proyecto, ni *transferir* totalmente la responsabilidad legal frente a un regulador, la fintech debe **mitigar** el riesgo implementando controles antes del consumo del servicio:

- **Explicabilidad e Interceptación (Gobernanza de IA) como se sugiere en el texto de la unidad 4:** Implementar un módulo intermedio (middleware/capa de evaluación) que aplique un marco de gobernanza sobre la API externa. Este módulo auditará las decisiones enviadas por la API, exigiendo métricas de **explicabilidad** (para saber por qué aprueba o rechaza un préstamo) y realizando pruebas periódicas de **auditoría de sesgo** (identificando disparidades por género, zona o demografía).
- **Visibilidad de Terceros (SBOM):** Exigir al proveedor un **Software Bill of Materials (SBOM)** o auditar las dependencias/SDKs expuestos para validar la integridad de la cadena de suministro de código.
- **Mecanismo "Human-in-the-Loop":** Configurar un umbral de decisión donde las solicitudes rechazadas por la IA o marcadas con alta incertidumbre pasen a revisión humana previa a la resolución final.

Estrategia de mitigación a elementos tangibles dentro de una metodología ágil (Scrum):

Utilizaremos:

- **Un Spike Técnico:** Para investigar e investigar la factibilidad técnica (fase de exploración).
- **Una Historia de Seguridad / Enabler Story:** Para implementar la solución técnica en el sistema (fase de desarrollo).

Spike Técnico (Investigación y Diseño)

¿Por qué un Spike? Dado que el modelo de IA es una "caja negra", el equipo primero debe investigar cómo medir la explicabilidad y cómo el proveedor entrega o permite evaluar dichos datos antes de programar.

- **ID / Título:** SPIKE-IA-01: Investigación e integración de marco de Gobernanza de IA (Explicabilidad y SBOM) para la API de crédito de terceros.
- **Descripción:** Como Arquitecto / Desarrollador, necesito evaluar las capacidades de la API de IA del proveedor respecto a la entrega de métricas de explicabilidad (ej. valores SHAP/LIME “estos nos permitirán saber porque el LLM tomo tal decisión”) y requerir la documentación de cadena de suministro (SBOM), con el fin de definir la arquitectura del middleware de mitigación de sesgos.
- **Criterios de Aceptación (Definition of Done del Spike):**
 1. Documentar si la API del proveedor expone los factores clave de decisión (explicabilidad) para cada evaluación crediticia.
 2. Solicitar y validar el **Software Bill of Materials (SBOM)** del SDK/API del proveedor para descartar vulnerabilidades conocidas en la cadena de suministro.
 3. Definir los umbrales de incertidumbre para el flujo *Human-in-the-Loop* (ej. créditos rechazados con puntaje límite).
 4. Diseñar la arquitectura del *middleware* que interceptará la API externa.
- **Estimación:** 3 Story Points (o 2-3 días persona dentro del Sprint).

Historia de Seguridad / Enabler Story (Implementación Tangible)

¿Por qué una Historia de Seguridad? Es la tarea que realmente añade el código y la lógica de protección en el producto final.

- **ID / Título:** SEC-IA-02: Implementar Middleware de Gobernanza de IA, Auditoría de Sesgo y Flujo *Human-in-the-Loop*.
- **Descripción:** Como Oficial de Cumplimiento / Usuario de la Fintech, quiero que el sistema intercepte y valide las evaluaciones de riesgo crediticio generadas por la IA de terceros, para asegurar la transparencia, evitar sesgos discriminatorios y derivar casos dudosos a revisión humana.
- **Criterios de Aceptación:**
 1. **Validación de Explicabilidad:** El middleware debe registrar los factores principales que motivaron la aprobación o rechazo del crédito antes de responder a la app móvil.
 2. **Enrutamiento Human-in-the-Loop:** Cualquier solicitud rechazada por la IA o con un nivel de confianza menor al 70% debe pasar automáticamente a una cola de revisión manual en el panel administrativo.
 3. **Registro para Auditoría (Logging):** Se deben almacenar logs cifrados con la entrada y salida anonimizada de la API para permitir auditorías regulatorias posteriores sobre posible discriminación/sesgo.
- **Estimación:** 8 Story Points.

2. Registro de riesgos híbrido y gobernanza en las ceremonias ágiles

El punto anterior identificó los riesgos del proyecto mediante Risk Storming. Este apartado resuelve el problema que aparece justo después: la organización exige un plan formal de gestión de riesgos con trazabilidad de auditoría, mientras que el equipo de desarrollo trabaja con Scrum y se niega a sostener un archivo de Excel que nadie abre entre una auditoría y la siguiente.

La tensión es real y tiene una causa identificable. Un registro de riesgos en una hoja de cálculo separada compite con el tablero donde el equipo trabaja todos los días, y siempre pierde. El resultado habitual es un documento que se actualiza dos veces, al inicio del proyecto y la víspera de la auditoría, con información que ya no describe el estado del sistema. El cumplimiento regulatorio de una fintech hace obligatorio conservar el registro, así que la solución que se propone aquí cambia dónde vive y quién lo alimenta.

El principio de diseño es el doble nivel de gestión de riesgos del enfoque híbrido: la capa predictiva conserva el artefacto formal y su gobernanza, y la capa ágil aporta el mecanismo de actualización. El registro deja de ser un archivo y pasa a ser una vista filtrada del mismo tablero que contiene el Product Backlog. Cada riesgo es un ítem etiquetado, y el historial de cambios que la herramienta genera de forma automática es la evidencia que el auditor necesita. La lectura de la unidad ya define este artefacto con esos seis campos ampliados: el registro vivo contiene descripción, dueño, probabilidad, impacto, puntuación y plan de respuesta (Sommerville, 2016; PMI, 2021). La puntuación y la trazabilidad al backlog forman parte de esa definición original, no son un agregado de este documento.

2.1 Diseño del registro de riesgos

El registro cabe en una página y contiene los seis campos que exige la auditoría: identificador, descripción, probabilidad, impacto, dueño y estado. Se agregan la puntuación calculada y la trazabilidad al backlog, porque sin esa columna el registro vuelve a ser un documento declarativo y no se puede demostrar que la mitigación ocurrió. La descripción de cada riesgo se redacta en formato condición y consecuencia, no como una etiqueta genérica. “Riesgo de proveedor” no es accionable; “el proveedor cambia el precio por consulta y la originación deja de ser rentable” sí lo es, porque nombra la causa y el efecto sobre un objetivo del proyecto (PMI, 2021). Las escalas de probabilidad e impacto son ordinales de 1 a 5 y la puntuación es su producto, con un rango de 1 a 25.

Apetito y umbral de riesgo de la organización: se aceptan sin plan de acción las puntuaciones de 1 a 8. Entre 9 y 14 el riesgo exige un ítem de mitigación comprometido en el sprint siguiente.

A partir de 15 se notifica al comité de dirección dentro de las 48 horas, el riesgo puede bloquear la liberación y su estado pasa a Escalado hasta que el comité aprueba una respuesta (PMI, 2021).

ID	Descripción (condición y consecuencia)	P	I	Score	Dueño	Estrategia y trazabilidad al backlog	Estado
R-01	La lógica de decisión crediticia se escribe acoplada al SDK del proveedor y sin pruebas de regresión para cumplir la fecha de salida, por lo que cada cambio de política de crédito exige reescribir y reprobar el módulo completo.	4	4	16	Líder Técnico	Mitigar. Enabler E-12 y reserva del 20% de la capacidad de cada sprint para refactorización.	Mitigándose
R-02	Una dependencia de terceros del pipeline serverless es comprometida en el repositorio central y expone las credenciales de la pasarela de pagos.	3	5	15	DevSecOps	Mitigar. SBOM en cada build, escaneo SCA bloqueante en el pipeline y rotación automática de secretos.	Mitigándose
R-03	El proveedor de la API de IA modifica sus términos de servicio, sus cuotas o su precio por consulta, o retira el modelo en uso, y la originación de préstamos queda sin motor de scoring.	4	5	20	Product Owner	Mitigar y transferir. Spike S-07 y Enabler E-14 para la capa de aislamiento; cláusula contractual de preaviso de 90 días y tope de variación de precio.	Escalado
R-04	El uso de servicios gestionados propietarios para funciones, colas y base de datos impide migrar de nube en un plazo razonable y elimina el poder de negociación frente al proveedor.	5	3	15	Arquitecto	Aceptación activa con reserva de contingencia. Documentar los puntos de acoplamiento en el ADR-04 y mantener la infraestructura como código portable.	En monitoreo
R-05	El modelo de scoring de terceros produce tasas de rechazo dispares entre cohortes demográficas, con exposición a sanción del regulador financiero y daño reputacional.	3	5	15	Product Owner y Compliance	Mitigar. Auditoría de equidad por cohorte antes de cada release y registro de las decisiones con su justificación explicable.	Escalado
R-06	Una sola persona conoce la integración con la pasarela de pagos, de modo que su ausencia detiene cualquier corrección sobre el flujo de desembolso.	3	3	9	Scrum Master	Mitigar. Revisión cruzada obligatoria de esos módulos y documentación mínima exigida por la Definition of Done.	Mitigándose

Figura 1. Registro de riesgos del proyecto, vista de una página generada desde el tablero. P = Probabilidad, I = Impacto, ambos en escala ordinal de 1 a 5; Score = P × I. Los identificadores R-01 a R-04 corresponden a los cuatro riesgos levantados en el Risk Storming del punto 1

El riesgo R-05, ligado al sesgo del modelo de scoring de un tercero, sigue el mismo enfoque de gobernanza de IA no determinista que describe el NIST AI RMF 1.0 (2023): exige explicabilidad y auditoría continua del comportamiento del modelo, no solo una revisión puntual antes del lanzamiento.

Los estados son seis y su transición es lo que la auditoría revisa. Abierto: el riesgo está identificado y su puntuación cae dentro del apetito de la organización, sin plan de acción comprometido. Escalado: la puntuación alcanzó el umbral de 15, el comité de dirección fue notificado dentro de las 48 horas y la respuesta todavía no está aprobada o iniciada. Mitigándose: existe un ítem activo en el Sprint Backlog trabajando la respuesta ya aprobada. En monitoreo: la respuesta se aplicó y queda riesgo residual bajo observación. Materializado: el riesgo ocurrió y se convirtió en un impedimento o incidente. Cerrado: dejó de ser posible. La distinción entre riesgo e impedimento importa porque un riesgo materializado ya no se gestiona con probabilidad e impacto, sino con acción correctiva inmediata.

2.2 Mecanismo de gobernanza: cómo se mantiene vivo el registro

La actualización ocurre dentro de eventos que el equipo ya realiza, con tiempo asignado dentro del timebox existente, sin agregar ninguna reunión nueva. El total de tiempo dedicado a riesgos es de unos 20 minutos por sprint de dos semanas, distribuidos como indica la tabla y sin exceder los límites que fija la Guía de Scrum para cada evento (Schwaber y Sutherland, 2020).

Evento	Qué ocurre con el registro	Tiempo	Evidencia para auditoría
Refinamiento del Backlog	Al descomponer una historia el equipo detecta riesgos nuevos y los registra en el momento, con dueño asignado.	5 min dentro del refinamiento	Ítem creado con fecha, autor y dueño

Sprint Planning	Se revisan los riesgos con puntuación igual o mayor a 9. Cada uno entra al sprint con un ítem de mitigación o queda registrada la razón de por qué no entra.	10 min de las 4 horas del timebox	Sprint Backlog con los ítems etiquetados como riesgo
Daily Scrum	Un riesgo que se materializó se reporta como impedimento y cambia de estado el mismo día.	Sin tiempo adicional	Cambio de estado a Materializado con marca de tiempo
Sprint Review	El incremento se presenta al patrocinador junto con la evidencia de las mitigaciones terminadas en el sprint.	Dentro de las 2 horas del evento	Acta de review y estado del registro en esa fecha
Sprint Retrospective	Radar de riesgos: el equipo reevalúa probabilidad e impacto a la luz de lo aprendido, cierra los que dejaron de aplicar y abre los que el sprint reveló.	10 min de la hora y media	Histórico de cambios de P, I y estado
Risk Storming	Sesión completa por cada release y ante cualquier cambio de arquitectura o de proveedor.	90 min, fuera de la cadencia	Lote de riesgos nuevos con acta de la sesión
Risk Storming	Sesión completa por cada release y ante cualquier cambio de arquitectura o de proveedor.	90 min, fuera de la cadencia	Lote de riesgos nuevos con acta de la sesión

Figura 2. Integración de la revisión de riesgos en la cadencia de Scrum.

Tres decisiones hacen que el mecanismo funcione y que no se convierta en burocracia.

La primera es la fuente única de verdad. El registro y el Product Backlog están en la misma

herramienta y el riesgo se relaciona con los ítems que lo mitigan mediante un vínculo, de modo que al cerrar la historia el riesgo cambia de estado sin transcripción manual. El documento de una página se genera por exportación automática del tablero, y esa exportación elimina la desactualización que motivó la objeción original del equipo, porque ya no existe un segundo lugar donde copiar la información.

La segunda es la propiedad nominal. Cada riesgo tiene una persona con nombre, nunca un rol colectivo ni “el equipo”, y esa persona responde por el estado del ítem en la retrospectiva. El Scrum Master facilita el radar de riesgos y cuida que el registro se actualice, pero no es dueño de los riesgos, porque eso reintroduciría la figura del gestor que centraliza el control y desactivaría la detección distribuida que da valor al Risk Storming.

La tercera es la extensión de la Definition of Done. Un ítem que mitiga un riesgo no se considera terminado hasta que el riesgo asociado quedó reevaluado en el registro, con la nueva probabilidad, el nuevo impacto y el riesgo residual anotado. Con esa regla la actualización se vuelve una condición de cierre del trabajo y deja de depender de la disciplina individual.

El auditor recibe dos cosas: la página exportada con el estado vigente y el historial de cambios de cada ítem, que muestra quién modificó qué y cuándo. Ese historial es una evidencia más sólida que un Excel firmado, porque registra la evolución del riesgo a lo largo de los sprints en lugar de una fotografía tomada el día anterior a la revisión (ISO 31000, 2018).

2.3 De riesgo a elemento del Product Backlog

El riesgo R-03 sirve para mostrar la traducción completa. Su enunciado es que el proveedor de la API de IA cambie sus términos de servicio, sus cuotas o su precio por consulta, con una probabilidad de 4 y un impacto de 5, para una puntuación de 20 que supera el umbral de escalamiento.

La respuesta se reparte en dos planos. Ninguna decisión técnica impide que el proveedor modifique su contrato, así que la probabilidad del evento queda fuera del control del equipo. Lo que el equipo sí controla es el impacto, y ahí se concentra el trabajo técnico. La parte contractual, negociar un preaviso de 90 días y un tope de variación de precio, es una transferencia parcial a cargo de la Product Owner y del área legal, y no genera ítems en el backlog.

El plano técnico produce dos elementos priorizados.

El primero es un spike, es decir una investigación acotada en el tiempo cuyo entregable es una decisión y no código de producción (Cohn, 2005).

S-07. Spike: evaluar dos proveedores alternativos de scoring crediticio. Timebox de dos días. Resultado esperado: matriz comparativa de paridad de atributos del modelo, latencia, costo por consulta y condiciones contractuales, con una recomendación firmada en un ADR. Estimación: 3 puntos.

El segundo es un Enabler de arquitectura, redactado como historia de habilitación porque su beneficiario es el propio sistema y no un usuario final.

E-14. Como equipo de originación, queremos que el scoring crediticio se consuma a través de un puerto interno propio y no del SDK del proveedor, para poder sustituir el motor de evaluación sin tocar el dominio de préstamos. Estimación: 13 puntos. Prioridad alta por mitigación de R-03.

Criterios de aceptación:

1. Ningún módulo del dominio importa el SDK del proveedor. Toda llamada pasa por la interfaz PuertoScoringCrediticio.
2. Existen dos adaptadores operativos: el proveedor actual y un motor de respaldo basado en reglas, con capacidad degradada y aprobación previa de riesgo crediticio.
3. Un feature flag permite conmutar de adaptador en producción sin desplegar una versión nueva.
4. Las pruebas de contrato de ambos adaptadores se ejecutan en verde dentro del pipeline de integración continua.
5. Un tablero registra el costo acumulado por consulta y emite alerta cuando el gasto mensual supera el 80% de lo presupuestado.
6. El registro de riesgos queda actualizado con la reevaluación de R-03, según exige la Definition of Done.

El efecto sobre el registro se anota al cerrar el Enabler. La probabilidad se mantiene en 4, porque el proveedor sigue siendo libre de cambiar sus condiciones. El impacto baja de 5 a 2,

porque el sistema puede conmutar de motor en minutos y seguir originando préstamos con capacidad reducida mientras se negocia o se migra. La puntuación pasa de 20 a 8, el riesgo sale del rango de escalamiento y su estado cambia de Escalado a En monitoreo, con un riesgo residual declarado: la degradación temporal de la precisión del scoring mientras opere el motor de respaldo.

Esa trazabilidad, del riesgo al ítem y del ítem de vuelta al riesgo con una puntuación distinta, es lo que convierte al registro en un artefacto vivo. El auditor no encuentra una promesa de mitigación escrita en una celda, sino un incremento desplegado, una prueba de contrato ejecutándose en el pipeline y un cambio de puntuación fechado y atribuido.

3. Identificación tradicional frente a Risk Storming: efectividad comparada

Los puntos anteriores mostraron qué riesgos aparecieron y cómo se gobierna su registro una vez identificados. Queda pendiente una pregunta distinta: si esos mismos cuatro riesgos deuda técnica por ausencia de reintentos, vulnerabilidad en la cadena de suministro del proveedor de IA, vendor lock-in del Serverless y sesgo algorítmico del modelo de scoring se hubieran buscado con una sesión tradicional, liderada únicamente por el Gerente de Proyecto y apoyada en una lista de verificación, ¿se habrían detectado con la misma profundidad? La respuesta es que no, y la razón no es una preferencia metodológica sino una limitación estructural de quién mira el sistema y con qué instrumento.

3.1 Limitaciones de la sesión tradicional liderada por el Gerente de Proyecto

Las técnicas tradicionales de identificación brainstorming, listas de verificación basadas en lecciones aprendidas y el método Delphi describen bien los riesgos recurrentes de cronograma, presupuesto y alcance que un PM observa proyecto tras proyecto (PMI, 2021). Su punto ciego aparece cuando el riesgo no vive en la gestión del proyecto sino dentro del propio artefacto técnico. **R-01**, la ausencia de lógica de reintentos frente a la API de IA, no es un riesgo que un checklist genérico contemple, porque es una decisión de implementación tomada por los desarrolladores bajo presión de plazo, invisible para quien no revisa el código o el diagrama de secuencia de la integración.

Lo mismo ocurre con **R-02**. Detectar que una dependencia de terceros puede traer una vulnerabilidad heredada exige inventariar librerías, versiones y CVEs conocidos, una tarea de auditoría técnica que corresponde a Seguridad o DevOps y que ningún checklist de lecciones aprendidas anticipa si el equipo no ha sufrido antes un incidente de cadena de suministro como Log4j o SolarWinds (OWASP, 2021). Un PM que trabaja solo tiende, además, a heredar el checklist del proyecto anterior, de modo que la sesión reproduce los riesgos ya conocidos de la organización en lugar de descubrir los que introduce esta arquitectura en particular: IA de terceros como caja negra e infraestructura Serverless de un único proveedor.

3.2 Por qué el enfoque multifuncional detecta mejor los riesgos técnicos y de ciberseguridad

El Risk Storming invierte el punto de partida: en vez de una lista abstracta, el equipo completo desarrolladores, QA, Product Owner, Arquitecto y DevOps/SRE observa el mismo diagrama de arquitectura o flujo de usuario y señala sobre él dónde falla cada pieza, democratizando la detección de amenazas en lugar de concentrarla en una sola persona. Esa diferencia de método explica la diferencia de cobertura observada en el punto 1: cada uno de los cuatro riesgos surgió del dominio de un rol distinto. El desarrollador identificó la deuda técnica porque conoce el estado real del código de integración; el especialista de DevOps/SRE reconoció el riesgo de cadena de suministro porque es quien administra los pipelines y los inventarios de dependencias; el Arquitecto señaló el vendor lock-in porque es quien dimensiona el costo de una migración futura; y el Product Owner, junto con la mirada regulatoria, planteó el riesgo ético y legal del sesgo algorítmico. Ninguno de los cuatro roles, actuando solo con una lista de verificación genérica, tenía visibilidad completa sobre el riesgo que detectó otro.

Esta paralelización del conocimiento es, precisamente, lo que exige la naturaleza no determinista de los riesgos modernos. Un modelo de IA de terceros se comporta como una caja negra difícil de auditar y puede introducir sesgos o alucinaciones que ningún PM puede anticipar sin criterios de explicabilidad propios del gobierno de IA (NIST AI RMF 1.0, 2023), del mismo modo que evaluar un vendor lock-in exige comprender el grado real de acoplamiento a servicios propietarios del proveedor de nube, algo que solo el Arquitecto puede estimar con precisión. El Risk Storming no es entonces una sesión "más participativa" por cortesía metodológica; es la

única estructura de identificación cuya cobertura de riesgo escala con la complejidad distribuida del sistema, porque reparte la carga de auditoría entre quienes efectivamente tienen control técnico sobre cada capa (ISO 31000, 2018).

3.3 Síntesis

En consecuencia, una sesión tradicional dirigida solo por el Gerente de Proyecto seguiría siendo útil para los riesgos clásicos de cronograma, costo y alcance, pero sistemáticamente subestimaría los riesgos técnicos y de ciberseguridad que hoy determinan la viabilidad de un producto financiero basado en IA y Serverless. El Risk Storming multifuncional, al trabajar directamente sobre la arquitectura y distribuir la detección entre los roles que la operan, es el enfoque adecuado para un proyecto como el de esta fintech, y su resultado los cuatro riesgos priorizados en el punto 1 y el registro vivo diseñado en el punto 2 es la evidencia de que esa cobertura ampliada se traduce en artefactos de gestión concretos y no solo en una discusión más larga.

Referencias Bibliográficas

Cohn, M. (2005). *Agile Estimating and Planning*. Prentice Hall.

ISO. (2018). *ISO 31000:2018 Risk Management — Guidelines*. International Organization for Standardization.

OWASP. (2021). *OWASP Top 10 – 2021: The Ten Most Critical Web Application Security Risks*. Open Web Application Security Project.

PMI. (2021). *A Guide to the Project Management Body of Knowledge (PMBOK Guide)* (6.^a ed.). Project Management Institute.

Schwaber, K., y Sutherland, J. (2020). *The Scrum Guide. The Definitive Guide to Scrum: The Rules of the Game*. Scrum.org y ScrumInc.

Sommerville, I. (2016). *Software Engineering* (10.^a ed.). Pearson Education.

Boehm, B. W. (1991). Software Risk Management: Principles and Practices. *IEEE Software*, 8(1), 32-41.